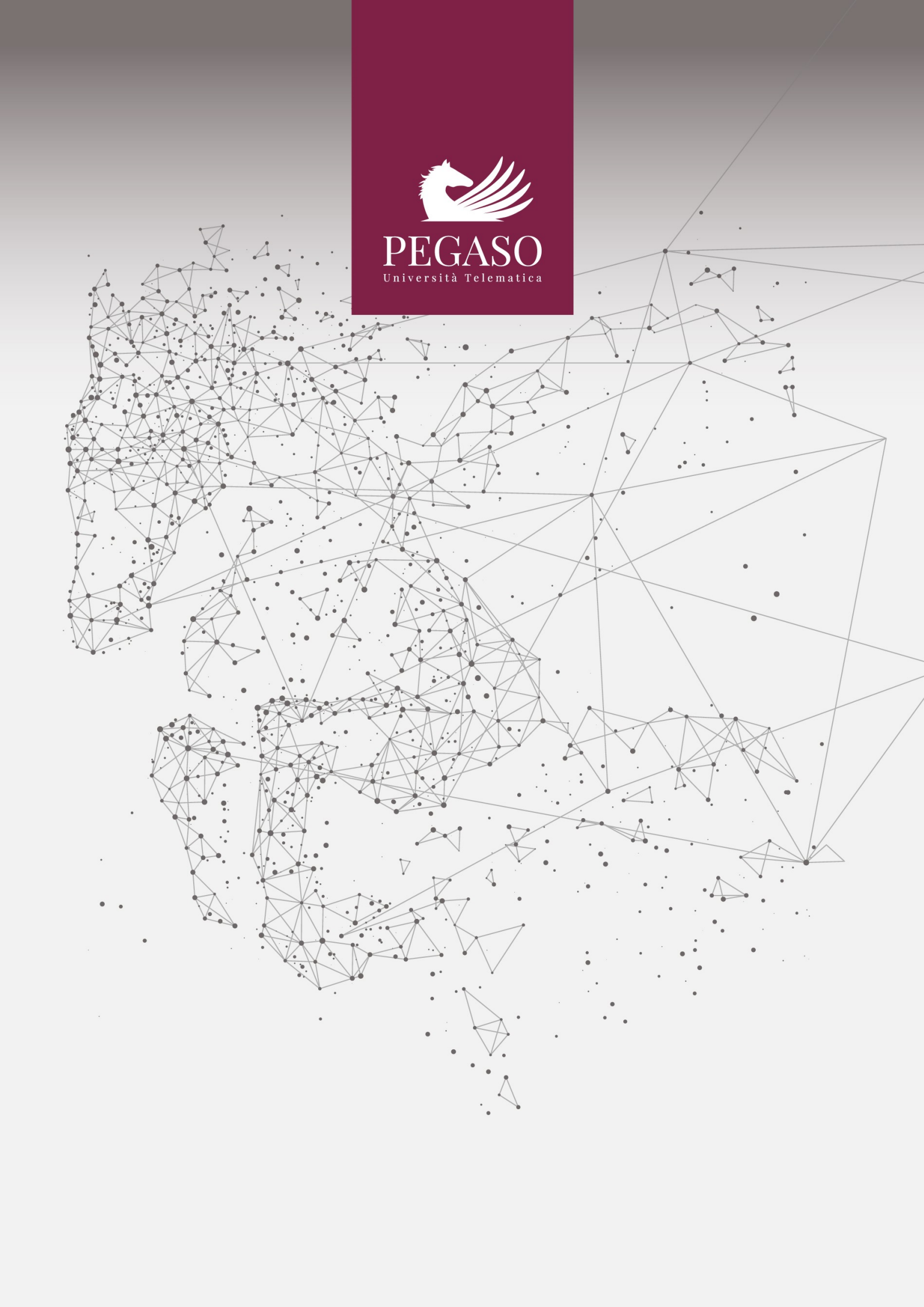

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 REQUISITI PER L'AUTENTICAZIONE 3

2 LE FUNZIONI DI AUTENTICAZIONE 5

2.1 CRITTOGRAFIA SIMMETRICA 5
2.2 CRITTOGRAFIA ASIMMETRICA 6

3 IL CODICE MAC 8

4 LA FUNZIONE HASH 9

BIBLIOGRAFIA 11

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Requisiti per l'autenticazione

L'area più complessa nel campo della sicurezza delle reti è sicuramente quella relativa all'**autenticazione dei messaggi** e alle **firme digitali**. Cerchiamo di definire i requisiti per l'autenticazione partendo dall'analisi dei possibili attacchi specifici che si possono avere nel contesto di una comunicazione di rete.

Tralasciando altri attacchi di cui si è già dibattuto in precedenza, consideriamo i seguenti:

1. **Mascheramento**: inserimento in rete di messaggi che provengono da una sorgente falsa
2. **Modifica dei contenuti**: alterazione/cancellazione dei contenuti di un messaggio
3. **Modifica delle sequenze**: modifica a una sequenza di messaggi fra due parti
4. **Modifica temporale**: ritardo o ripetizione di messaggi
5. **Ripudio del mittente**: il mittente nega di aver trasmesso il messaggio
6. **Ripudio del destinatario**: il destinatario nega di aver ricevuto il messaggio

Le problematiche generate dagli attacchi da 1 a 4 impattano proprio sull'autenticazione del messaggio e sulla necessità di sviluppare delle funzionalità che garantiscano i dati che vengono trasmessi. La problematica 5 riguarda invece la firma digitale (la firma digitale può anche risolvere gli attacchi da 1 a 4) che serve appunto per associare il messaggio al mittente come accade nel caso di firma autografa su un documento cartaceo. Per la problematica 6 occorre impiegare una combinazione di firma digitale e di protocolli specifici.

In generale quello che si può sostanzialmente affermare e che si deve tener presente nell'analisi delle varie funzionalità all'interno di questa lezione è che:

- **L'autenticazione dei messaggi** è una procedura che verifica che i messaggi ricevuti provengano dalla sorgente indicata e non siano stati modificati.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- **La firma digitale** è una tecnica di autenticazione che impedisce al mittente di negare di aver trasmesso un certo messaggio

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 Le funzioni di autenticazione

Nella realizzazione di una funzione di autenticazione ciò che si cerca di produrre è un cosiddetto *autenticatore*, ovvero un valore che verrà utilizzato per autenticare il messaggio all'interno di un determinato protocollo di autenticazione. Tale autenticatore può essere generato ricorrendo sostanzialmente a l'uso delle seguenti tre tecniche:

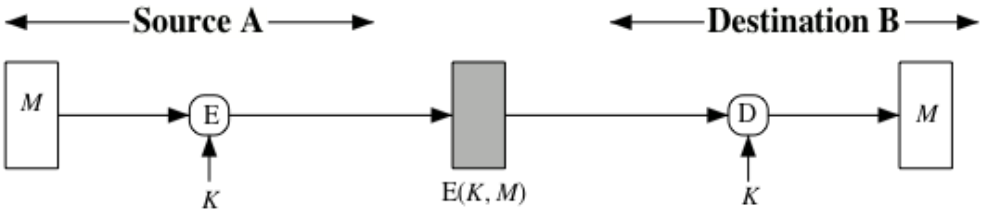
- *La crittografia dei messaggi* (simmetrica o asimmetrica)
- *Il codice MAC* (Message Authentication Code)
- *Le funzione hash*

Vediamo intanto l'utilizzo della crittografia che è già stata introdotta in precedenza, per poi presentare MAC e funzioni hash.

2.1 Crittografia simmetrica

Nel caso di utilizzo della crittografia simmetrica, il messaggio M trasmesso da A verso B viene cifrato usando la chiave segreta K condivisa da entrambe le parti; questo approccio (vedi figura sottostante) garantisce:

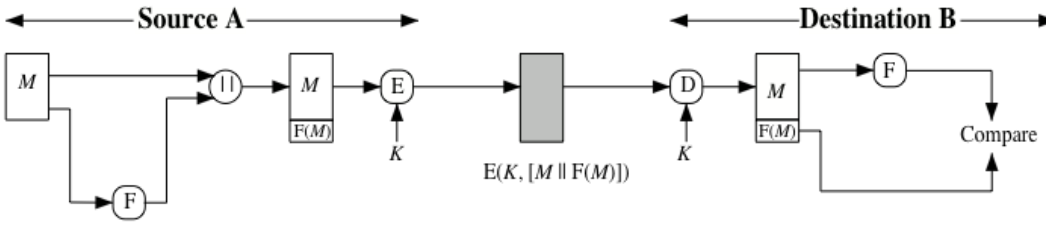
- *segretezza*: nessuno eccetto A e B conosce la chiave segreta K
- *autenticazione*: solo A può avere inviato il messaggio e nessuno può averlo modificato



Ovviamente non è garantita la firma digitale in quanto anche B possiede la stessa chiave K.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

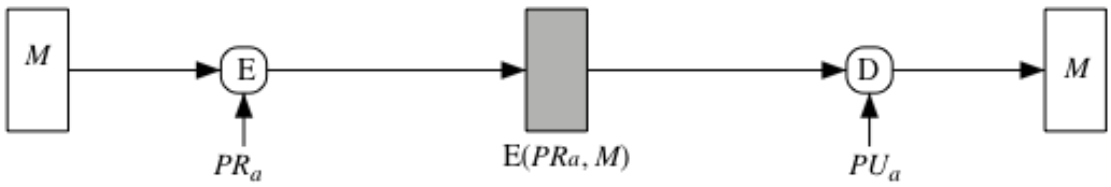
Tuttavia esiste anche il problema per B di capire se accettare il testo decifrato come legittimo se esso non è intelligibile, ovvero se il messaggio M è costituito da una sequenza non strutturata (p.e. non è scritto in inglese). Potrebbe verificarsi il caso che il server dell'utente B si trova sotto attacco e riceve messaggi che lui decifra con la chiave K ma il cui risultato potrebbe non avere senso. Per ovviare a ciò si aggiunge un checksum generato a partire dal messaggio M attraverso una funzione F condivisa tra le due parti (vedi figura). Se la verifica del checksum è positiva allora il messaggio è autentico.



(a) Internal error control

2.2 Crittografia asimmetrica

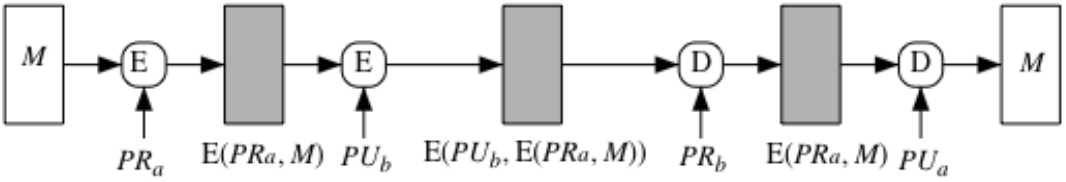
In questo caso si usa sempre la crittografia ma stavolta quella asimmetrica (vedi figura sottostante).



Essa *non garantisce la segretezza* (chiunque può usare la chiave pubblica PU_a per leggere il messaggio M) ma *garantisce l'autenticazione e la firma digitale* in quanto solo A possiede PR_a. Anche in questo caso, come in precedenza, il messaggio deve possedere una certa struttura che possa essere riconosciuta per accettarlo come valido e distinguerlo da una sequenza casuale.

Per garantire segretezza, autenticazione e firma digitale, A deve usare prima la sua chiave privata PR_a e poi la chiave pubblica del destinatario PU_b come evidenziato in figura:

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

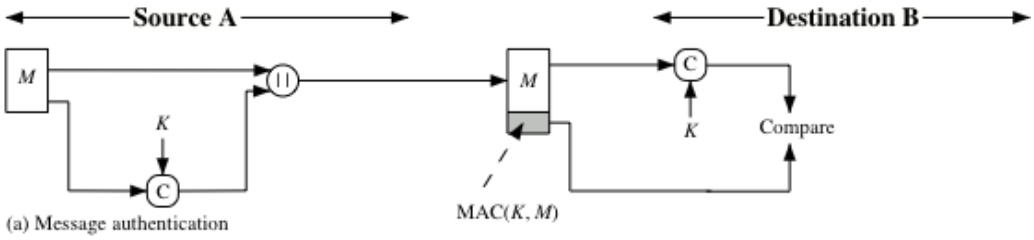


PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Il codice MAC

Un'altra tecnica per ottenere l'autenticazione prevede l'uso di un codice **MAC** (*Message Authentication Code*) che viene generato attraverso una chiave segreta K condivisa, producendo un piccolo blocco di dati di dimensione fissa (vedi figura) dipendente da M e da K che viene allegato al messaggio M.

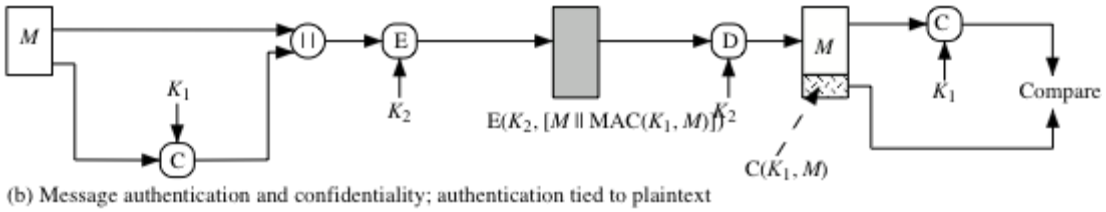


(a) Message authentication

Un vantaggio della funzione MAC è che non deve essere reversibile.

Tale procedura *garantisce l'autenticazione* (solo A, oltre a B, possiede la chiave segreta K) ma, *non garantisce la segretezza* in quanto il messaggio M è trasmesso in chiaro.

Al fine di garantire anche la segretezza viene introdotta una seconda chiave (vedi figura) per cifrare tutto il pacchetto prima del suo invio.



(b) Message authentication and confidentiality; authentication tied to plaintext

È importante notare che il codice MAC non garantisce mai la firma digitale poiché sia A che B condividono la stessa chiave (chiavi).

.

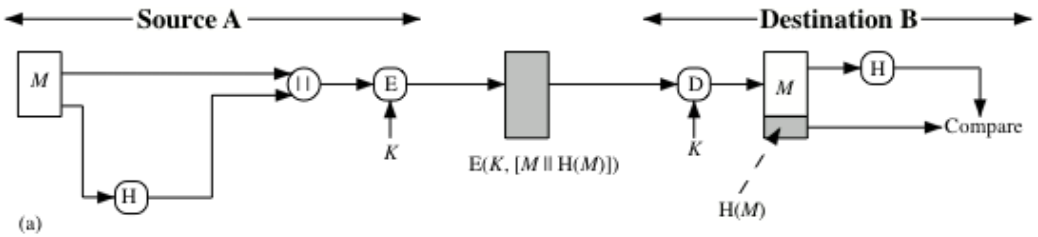
PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

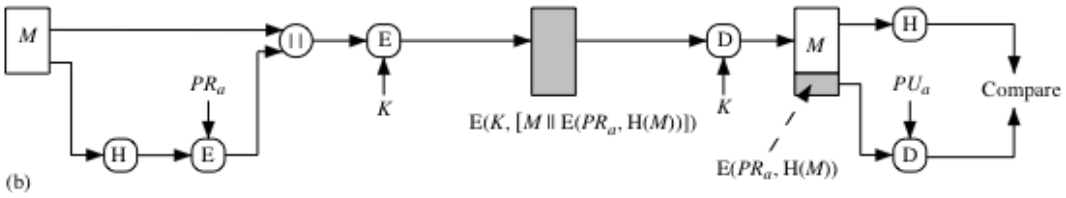
4 La funzione hash

Un'altra soluzione consiste nell'uso di una funzione di **hash** monodirezionale. Come il codice MAC, anche la funzione di hash accetta come input un messaggio di lunghezza variabile e produce un output di lunghezza fissa (*digest*) ma a differenza del codice MAC non dipende da una chiave. Esistono vari modo per usare la funzione hash…vediamone alcuni.

Un primo metodo prevede l'utilizzo della crittografia simmetrica (vedi figura) in cui viene *garantita sia l'autenticazione che la segretezza ma non la firma digitale*.

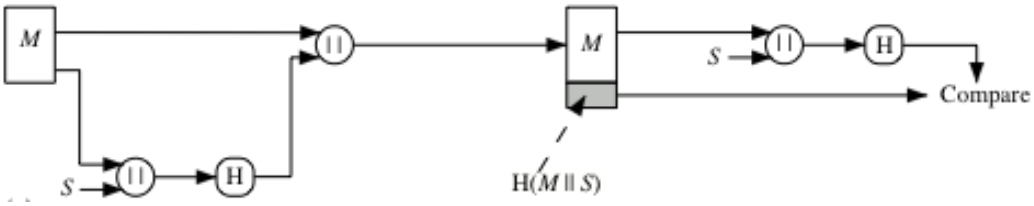


Un secondo metodo prevede invece l'uso congiunto della crittografia asimmetrica e di quella simmetrica (vedi figura); in questo caso viene *garantita sia l'autenticazione sia la segretezza* (tramite la chiave simmetrica K) ed anche *la firma digitale* (tramite l'uso di PR_a).



Un terzo metodo invece si basa sull'utilizzo della funzione hash senza crittografia, basta che le due parti condividano un valore segreto S (vedi figura).

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



In questa situazione viene *garantita l'autenticazione* (il valore S non viene inviato ed è noto solo ad A e B) ma *non la segretezza* (si dovrebbe aggiungere una cifratura simmetrica prima dell'invio).

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: *Capitolo 11*.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).